PROJET PERSONNEL – SÉCURITÉ DES SYSTÈMES

RAPPORT D'AUDIT

Audit de durcissement Windows

inspiré du CIS Microsoft Windows 10 Benchmark – automatisé en PowerShell

34	47 % → 94 %	18 → 2
contrôles par poste	score des postes durcis	non-conformités par poste

RÉALISÉ PAR

Leslie Kamguem Tadjuidje

Étudiante ingénieure en cybersécurité – EFREI Paris

Audit réalisé le 9 novembre 2026

1. Synthèse

Ce rapport présente l'audit de durcissement d'un parc de trois postes Windows 10, réalisé avec un outil PowerShell développé pour l'occasion. L'outil vérifie à distance, par WinRM, **34 contrôles de sécurité inspirés du CIS Benchmark**, calcule un score de conformité par poste et produit des rapports HTML et CSV. Un second script applique les corrections sans risque.

L'audit initial donne un score moyen de **48,1 %**, typique d'un Windows installé par défaut. Après remédiation automatisée de PC02 et PC03, leur score passe de **47,1 % à 94,1 %**. PC01, conservé volontairement comme poste témoin, reste à 50 %. Les deux écarts restants sur les postes durcis sont des limites connues du laboratoire, acceptées et documentées.

Poste	Rôle	Score avant	Score après	Non-conformités	Évolution
PC01	Poste témoin (non corrigé)	50,0 %	50,0 %	17 → 17	Inchangé
PC02	Poste durci	47,1 %	94,1 %	18 → 2	+47 points
PC03	Poste durci	47,1 %	94,1 %	18 → 2	+47 points
Parc		48,1 %	79,4 %	53 → 21	**+31 points**

Contexte et objectifs

Un poste Windows installé par défaut conserve des réglages risqués : protocole SMBv1 actif (exploité par le rançongiciel WannaCry), absence de verrouillage après des mots de passe erronés, résolution de noms LLMNR exploitable pour voler des empreintes de mots de passe, journaux trop petits pour mener une investigation. Le **CIS Benchmark** est un référentiel reconnu qui définit les réglages recommandés. Vérifier ces réglages manuellement sur chaque poste est long et source d'erreurs : l'objectif est donc de :

- mesurer automatiquement le niveau de durcissement de plusieurs postes depuis un poste d'administration ;
- prioriser les écarts par sévérité ;
- corriger les écarts courants de façon reproductible ;
- prouver l'amélioration par un nouvel audit chiffré.

2. Environnement et méthode

Laboratoire

Poste	Adresse IP	Rôle	Système
PC01	192.168.10.11	Poste d'administration (exécute les scripts) et poste témoin audité	Windows 10 Éducation 64 bits
PC02	192.168.10.12	Poste audité puis durci	Windows 10 Éducation 64 bits
PC03	192.168.10.13	Poste audité puis durci	Windows 10 Éducation 64 bits

Les postes sont des machines virtuelles VMware Workstation, hors domaine Active Directory, administrées par PowerShell Remoting (WinRM, port 5985).

Outils développés

Script	Rôle
`Invoke-CISAudit.ps1`	Audit en **lecture seule** : 34 contrôles par poste, score, rapport HTML et CSV, journal. Un poste injoignable est classé INACCESSIBLE sans interrompre l'audit.
`Invoke-CISRemediation.ps1`	Applique 17 mesures de durcissement sur les postes choisis. Le mode `-Simulation` affiche les changements sans rien modifier.

Contrôles vérifiés

Catégorie	Nb	Exemples
Mots de passe et verrouillage	6	Longueur ≥ 14, complexité, historique ≥ 24, verrouillage après 5 échecs pendant 15 min
Comptes	3	Comptes Invité et Administrateur intégré désactivés, taille du groupe Administrateurs
Réseau	7	SMBv1 désactivé, signature SMB, LLMNR désactivé, NTLMv2 uniquement, RDP/NLA, WinRM chiffré et sans Basic
Pare-feu	4	Actif sur les profils Domaine, Privé et Public ; entrant bloqué par défaut
Antivirus	2	Protection Defender en temps réel, signatures de moins de 7 jours
Système	7	UAC, AutoRun, Windows Update, Registre à distance, BitLocker, PowerShell 2.0
Journalisation	5	Script Block Logging, journal Sécurité ≥ 192 Mo, audit des ouvertures de session, des comptes et des processus

Démarche

1. **Audit initial** des 3 postes, pour établir l'état de départ.

2. **Simulation** de la remédiation sur PC02, pour valider les changements avant de les appliquer.
3. **Remédiation** de PC02 et PC03 ; PC01 est conservé comme témoin.
4. **Redémarrage** des postes corrigés, puis **nouvel audit** pour mesurer le gain.

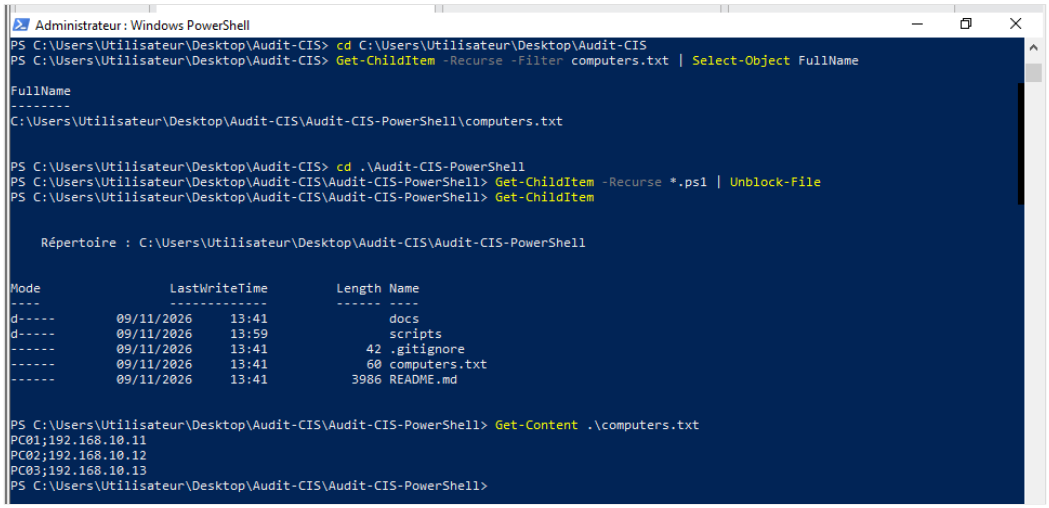


Figure 1 – Dossier du projet sur PC01 et liste des postes à auditer

3. Audit initial

L'audit initial donne un score moyen de **48,1 %** sur le parc : 53 non-conformités, dont 14 de sévérité élevée. Les trois postes présentent un profil très proche, typique d'une installation par défaut.

```
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell> .\scripts\Invoke-CISAudit.ps1
Audit de PC01 (192.168.10.11)...
Audit de PC02 (192.168.10.12)...
Audit de PC03 (192.168.10.13)...

--- Synthèse de l'audit CIS ---

Poste IP            Etat   Conformes NonConformes NonEvalues Score (%) Critiques
----- --            ----   --------- ------------ ---------- --------- ---------
PC01  192.168.10.11 AUDITÉ        17           17          0        50         4
PC02  192.168.10.12 AUDITÉ        16           18          0      47,1         5
PC03  192.168.10.13 AUDITÉ        16           18          0      47,1         5


Score moyen du parc : 48.1 %

Rapport CSV  : .\Rapports\CIS-Audit-20261109-1423.csv
Rapport HTML : .\Rapports\CIS-Audit-20261109-1423.html
Journal      : .\Rapports\CIS-Audit.log
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell>
```

Figure 2 – Audit initial en console : scores de 47,1 % à 50 %

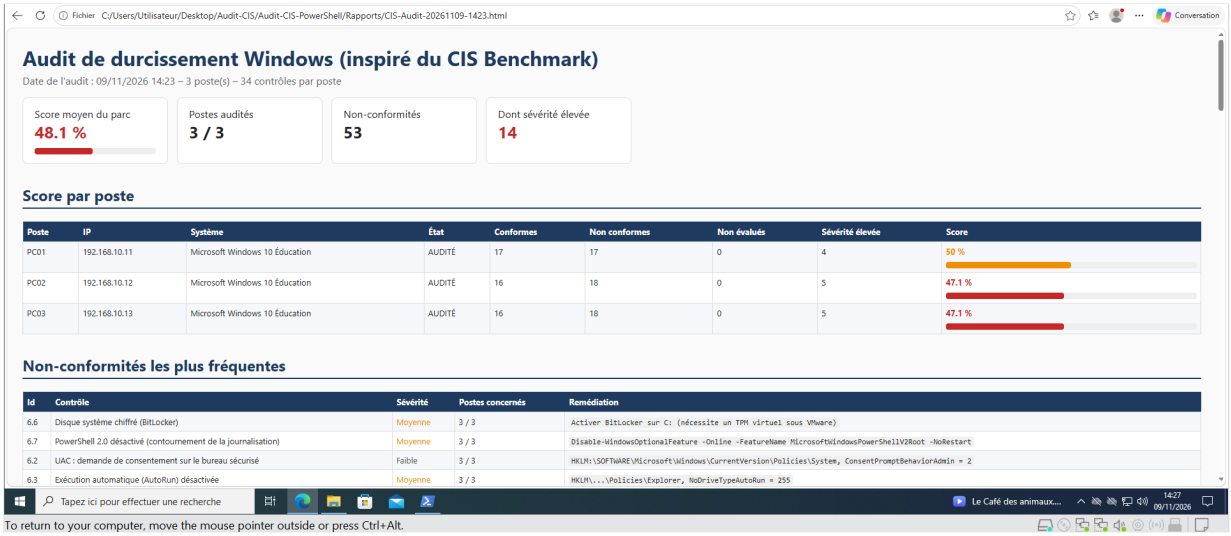


Figure 3 – Rapport HTML de l'audit initial : synthèse et score par poste

Principaux écarts relevés

Écart	Sévérité	Risque
Authentification LM / NTLMv1 acceptée	Élevée	Empreintes de mots de passe faciles à casser ou à relayer
Aucun verrouillage de compte	Élevée	Attaque par force brute sur les mots de passe sans limite
Mots de passe courts et sans historique	Élevée	Mots de passe faibles ou réutilisés
LLMNR actif	Moyenne	Vol d'empreintes par empoisonnement de la résolution de noms (Responder)
PowerShell 2.0 présent, pas de Script Block Logging	Moyenne	Exécution de scripts malveillants sans trace exploitable
Journal Sécurité trop petit, audit des processus absent	Moyenne	Investigation impossible après un incident
AutoRun actif	Moyenne	Exécution automatique de code depuis un support amovible



Non-conformités les plus fréquentes

Id	Contrôle	Sévérité	Postes concernés	Remédiation
6.6	Disque système chiffré (BitLocker)	Moyenne	3 / 3	`Activer BitLocker sur C: (nécessite un TPM virtuel sous VMware)`
6.7	PowerShell 2.0 désactivé (contournement de la journalisation)	Moyenne	3 / 3	`Disable-WindowsOptionalFeature -Online -FeatureName MicrosoftWindowsPowerShellV2Root -NoRestart`
6.2	UAC : demande de consentement sur le bureau sécurisé	Faible	3 / 3	`HKLM:\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System, ConsentPromptBehaviorAdmin = 2`
6.3	Exécution automatique (AutoRun) désactivée	Moyenne	3 / 3	`HKLM\...\Policies\Explorer, NoDriveTypeAutoRun = 255`
7.4	Audit de la gestion des comptes utilisateur	Moyenne	3 / 3	`auditpol /set /subcategory:"{0CCE9235-69AE-11D9-BED3-505054503030}" /success:enable /failure:enable`
7.5	Audit de la création de processus	Moyenne	3 / 3	`auditpol /set /subcategory:"{0CCE922B-69AE-11D9-BED3-505054503030}" /success:enable`
7.1	Journalisation des blocs de script PowerShell	Moyenne	3 / 3	`HKLM\SOFTWARE\Policies\Microsoft\Windows\PowerShell\ScriptBlockLogging, EnableScriptBlockLogging = 1`
7.2	Taille du journal Sécurité	Moyenne	3 / 3	`wevtutil sl Security /ms:201326592`
3.4	Authentification NTLMv2 uniquement (refus LM/NTLMv1)	Élevée	3 / 3	`HKLM\SYSTEM\CurrentControlSet\Control\Lsa, LmCompatibilityLevel = 5`
1.3	Durée de vie maximale du mot de passe	Moyenne	3 / 3	`net accounts /maxpwage:365`

Figure 4 – Non-conformités les plus fréquentes, avec la remédiation proposée

4. Remédiation

Avant toute modification, la remédiation a été simulée sur PC02 : le mode `-Simulation` liste les 17 mesures prévues sans rien changer. Cette étape correspond à la bonne pratique de validation préalable des changements.

```
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell> .\scripts\Invoke-CISRemediation.ps1 -Computers PC02 -Simulation

=== Remédiation de PC02 (192.168.10.12) (simulation) ===

Id          Mesure                                                  Resultat
--          ------                                                  --------
1.1/1.3/1.4 Mots de passe : longueur 14, durée max 365 j, historique 24   SIMULATION
1.2         Mots de passe : complexité exigée                       SIMULATION
1.5/1.6     Verrouillage : 5 tentatives, 15 minutes                 SIMULATION
2.1         Compte Invité désactivé                                 SIMULATION
3.1         SMBv1 désactivé                                         SIMULATION
3.2         Signature SMB exigée                                    SIMULATION
3.3         LLMNR désactivé                                         SIMULATION
3.4         NTLMv2 uniquement                                       SIMULATION
4.x         Pare-feu actif sur les 3 profils, entrant bloqué par défaut   SIMULATION
6.1/6.2     UAC activé avec consentement sur le bureau sécurisé     SIMULATION
6.3         AutoRun désactivé sur tous les lecteurs                 SIMULATION
6.5         Service Registre à distance désactivé                   SIMULATION
6.7         PowerShell 2.0 désactivé (redémarrage éventuel)         SIMULATION
7.1         Journalisation des blocs de script PowerShell           SIMULATION
7.2         Journal Sécurité porté à 192 Mo                         SIMULATION
7.3/7.4/7.5 Stratégie d'audit : ouvertures de session, comptes, processus SIMULATION


Relancez .\Invoke-CISAudit.ps1 pour mesurer le gain de conformité.
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell>
```

Figure 5 – Simulation de la remédiation sur PC02 : aucune modification appliquée

Les mesures ont ensuite été appliquées sur PC02 et PC03 : les **17 mesures** ont réussi sur les deux postes, sans échec. Les postes ont été redémarrés pour finaliser certains réglages (PowerShell 2.0, UAC).

```
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell> .\scripts\Invoke-CISRemediation.ps1 -Computers PC02, PC03

=== Remédiation de PC02 (192.168.10.12) ===

Id          Mesure                                                  Resultat
--          ------                                                  --------
1.1/1.3/1.4 Mots de passe : longueur 14, durée max 365 j, historique 24   APPLIQUÉ
1.2         Mots de passe : complexité exigée                       APPLIQUÉ
1.5/1.6     Verrouillage : 5 tentatives, 15 minutes                 APPLIQUÉ
2.1         Compte Invité désactivé                                 APPLIQUÉ
3.1         SMBv1 désactivé                                         APPLIQUÉ
3.2         Signature SMB exigée                                    APPLIQUÉ
3.3         LLMNR désactivé                                         APPLIQUÉ
3.4         NTLMv2 uniquement                                       APPLIQUÉ
4.x         Pare-feu actif sur les 3 profils, entrant bloqué par défaut   APPLIQUÉ
6.1/6.2     UAC activé avec consentement sur le bureau sécurisé     APPLIQUÉ
6.3         AutoRun désactivé sur tous les lecteurs                 APPLIQUÉ
6.5         Service Registre à distance désactivé                   APPLIQUÉ
6.7         PowerShell 2.0 désactivé (redémarrage éventuel)         APPLIQUÉ
7.1         Journalisation des blocs de script PowerShell           APPLIQUÉ
7.2         Journal Sécurité porté à 192 Mo                         APPLIQUÉ
7.3/7.4/7.5 Stratégie d'audit : ouvertures de session, comptes, processus APPLIQUÉ


=== Remédiation de PC03 (192.168.10.13) ===

Id          Mesure                                                  Resultat
--          ------                                                  --------
1.1/1.3/1.4 Mots de passe : longueur 14, durée max 365 j, historique 24   APPLIQUÉ
1.2         Mots de passe : complexité exigée                       APPLIQUÉ
1.5/1.6     Verrouillage : 5 tentatives, 15 minutes                 APPLIQUÉ
2.1         Compte Invité désactivé                                 APPLIQUÉ
3.1         SMBv1 désactivé                                         APPLIQUÉ
3.2         Signature SMB exigée                                    APPLIQUÉ
3.3         LLMNR désactivé                                         APPLIQUÉ
3.4         NTLMv2 uniquement                                       APPLIQUÉ
4.x         Pare-feu actif sur les 3 profils, entrant bloqué par défaut   APPLIQUÉ
6.1/6.2     UAC activé avec consentement sur le bureau sécurisé     APPLIQUÉ
6.3         AutoRun désactivé sur tous les lecteurs                 APPLIQUÉ
6.5         Service Registre à distance désactivé                   APPLIQUÉ
6.7         PowerShell 2.0 désactivé (redémarrage éventuel)         APPLIQUÉ
7.1         Journalisation des blocs de script PowerShell           APPLIQUÉ
7.2         Journal Sécurité porté à 192 Mo                         APPLIQUÉ
7.3/7.4/7.5 Stratégie d'audit : ouvertures de session, comptes, processus APPLIQUÉ


Relancez .\Invoke-CISAudit.ps1 pour mesurer le gain de conformité.
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell>
```

Figure 6 – Remédiation de PC02 et PC03 : 17 mesures appliquées sur chaque poste

> **Mesures volontairement non automatisées.** La désactivation du compte Administrateur intégré et la modification de WinRM, du Bureau à distance ou de BitLocker pourraient couper l'accès d'administration au laboratoire. Elles restent signalées par l'audit et sont traitées comme des décisions à prendre au cas par cas.

5. Audit après remédiation

Le nouvel audit confirme l'efficacité du durcissement : PC02 et PC03 atteignent **94,1 %** (32 contrôles conformes sur 34), contre 47,1 % au départ. Le poste témoin PC01 reste à 50 %, ce qui confirme que le gain est bien dû à la remédiation. Le score moyen du parc passe de 48,1 % à **79,4 %**.

```
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell> $cred = Get-Credential

applet de commande Get-Credential à la position 1 du pipeline de la commande
Fournissez des valeurs pour les paramètres suivants :
Credential
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell> Invoke-Command -ComputerName 192.168.10.12 -Credential $cred -ScriptBlock { hostname }
PC02
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell> .\scripts\Invoke-CISAudit.ps1 -Credential $cred
Audit de PC01 (192.168.10.11)...
Audit de PC02 (192.168.10.12)...
Audit de PC03 (192.168.10.13)...

--- Synthèse de l'audit CIS ---

Poste IP            Etat   Conformes NonConformes NonEvalues Score (%) Critiques
----- --            ----   --------- ------------ ---------- --------- ---------
PC01  192.168.10.11 AUDITÉ        17           17          0        50         4
PC02  192.168.10.12 AUDITÉ        32            2          0      94,1         1
PC03  192.168.10.13 AUDITÉ        32            2          0      94,1         1


Score moyen du parc : 79.4 %

Rapport CSV  : .\Rapports\CIS-Audit-20261109-1526.csv
Rapport HTML : .\Rapports\CIS-Audit-20261109-1526.html
Journal      : .\Rapports\CIS-Audit.log
PS C:\Users\Utilisateur\Desktop\Audit-CIS\Audit-CIS-PowerShell>
```

Figure 7 – Audit après remédiation : PC02 et PC03 à 94,1 %, PC01 inchangé

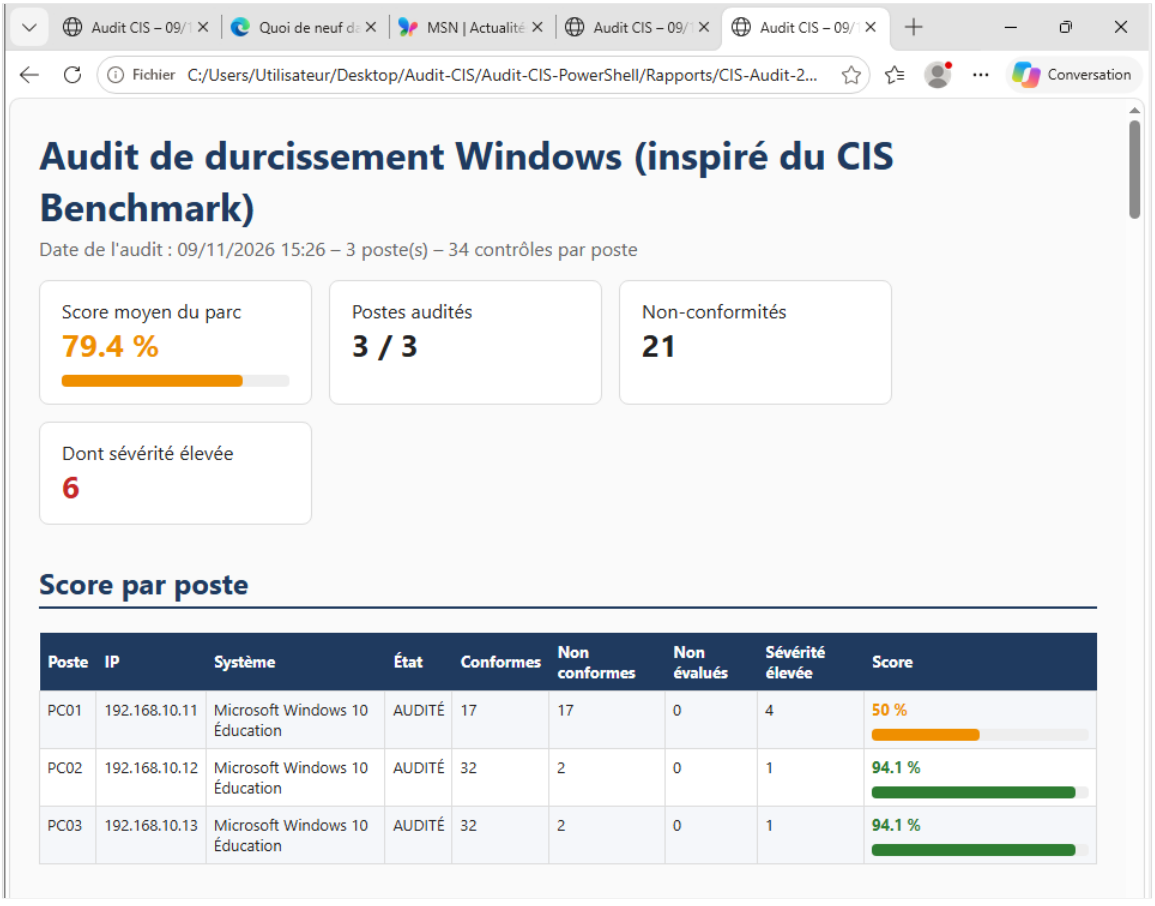


Figure 8 – Rapport HTML après remédiation : score par poste

Id	Catégorie	Contrôle	Attendu	Valeur actuelle	Statut	Sévérité
1.1	Mots de passe	Longueur minimale du mot de passe	>= 14 caractères	14	CONFORME	Élevée
1.2	Mots de passe	Complexité du mot de passe exigée	1 (activée)	1	CONFORME	Élevée
1.3	Mots de passe	Durée de vie maximale du mot de passe	1 à 365 jours	365	CONFORME	Moyenne
1.4	Mots de passe	Historique des mots de passe	>= 24	24	CONFORME	Moyenne
1.5	Mots de passe	Seuil de verrouillage du compte	1 à 5 tentatives	5	CONFORME	Élevée
1.6	Mots de passe	Durée de verrouillage du compte	>= 15 minutes	15	CONFORME	Moyenne
2.1	Comptes	Compte Invité désactivé	Désactivé	Désactivé	CONFORME	Élevée
2.2	Comptes	Compte Administrateur intégré désactivé	Désactivé	Désactivé	CONFORME	Moyenne
2.3	Comptes	Nombre de membres du groupe Administrateurs	<= 2	2 (PC02\Administrateur, PC02\Utilisateur)	CONFORME	Moyenne
3.1	Réseau	SMBv1 désactivé	False	False	CONFORME	Élevée
3.2	Réseau	Signature SMB exigée (serveur)	True	True	CONFORME	Moyenne
3.3	Réseau	LLMNR désactivé	0	0	CONFORME	Moyenne
3.4	Réseau	Authentification NTLMv2 uniquement (refus LM/NTLMv1)	5	5	CONFORME	Élevée
3.5	Réseau	Bureau à distance désactivé ou protégé par NLA	RDP désactivé ou NLA = 1	RDP désactivé	CONFORME	Moyenne
3.6	Réseau	WinRM : trafic non chiffré refusé	false	false	CONFORME	Élevée
3.7	Réseau	WinRM : authentification Basic désactivée	false	false	CONFORME	Élevée
4.1	Pare-feu	Pare-feu actif – profil Domain	True	True	CONFORME	Élevée
4.2	Pare-feu	Pare-feu actif – profil Private	True	True	CONFORME	Élevée
4.3	Pare-feu	Pare-feu actif – profil Public	True	True	CONFORME	Élevée
4.4	Pare-feu	Connexions entrantes bloquées par défaut – profil Public	Block	Block	CONFORME	Moyenne
5.1	Antivirus	Defender : protection en temps réel active	True	True	CONFORME	Élevée
5.2	Antivirus	Defender : signatures à jour	<= 7 jours	123 jour(s)	NON CONFORME	Élevée
6.1	Système	Contrôle de compte utilisateur (UAC) activé	1	1	CONFORME	Élevée
6.2	Système	UAC : demande de consentement sur le bureau sécurisé	2	2	CONFORME	Faible
6.3	Système	Exécution automatique (AutoRun) désactivée	255	255	CONFORME	Moyenne
6.4	Système	Service Windows Update non désactivé	Différent de Disabled	Manual	CONFORME	Élevée
6.5	Système	Service Registre à distance désactivé	Disabled	Disabled	CONFORME	Moyenne
6.6	Système	Disque système chiffré (BitLocker)	Protégé	Non chiffré	NON CONFORME	Moyenne
6.7	Système	PowerShell 2.0 désactivé (contournement de la journalisation)	Disabled	Disabled	CONFORME	Moyenne
7.1	Journalisation	Journalisation des blocs de script PowerShell	1	1	CONFORME	Moyenne
7.2	Journalisation	Taille du journal Sécurité	>= 192 Mo	192 Mo	CONFORME	Moyenne
7.3	Journalisation	Audit des ouvertures de session (succès et échecs)	Succès et échec	Succès et échec	CONFORME	Élevée
7.4	Journalisation	Audit de la gestion des comptes utilisateur	Succès et échec	Succès et échec	CONFORME	Moyenne
7.5	Journalisation	Audit de la création de processus	Succès	Succès	CONFORME	Moyenne

Figure 9 – Détail des contrôles de PC02 après remédiation : seuls 5.2 et 6.6 restent non conformes

6. Risques résiduels et recommandations

Écarts restants sur les postes durcis

Contrôle	Constat	Décision
5.2 Signatures Defender à jour	Signatures datant de 123 jours : les VM du laboratoire n'ont pas d'accès à Internet	Risque accepté en laboratoire ; en production, mise à jour automatique ou via un serveur WSUS
6.6 Chiffrement BitLocker	Disque non chiffré : BitLocker nécessite un TPM virtuel non configuré sous VMware	Risque accepté ; à activer sur les postes physiques, clés de récupération sauvegardées

Recommandations pour le poste témoin et la généralisation

- Appliquer la remédiation à PC01 une fois la phase de démonstration terminée.
- Créer un compte d'administration nominatif, puis désactiver le compte Administrateur intégré.
- En entreprise, déployer ces réglages par **stratégie de groupe (GPO)** plutôt que par script, et planifier l'audit (tâche planifiée) pour détecter toute dérive de configuration.
- Étendre l'outil aux autres recommandations du CIS Benchmark (plus de 300) et à Windows Server.

Difficultés rencontrées

Difficulté	Cause	Solution
Contrôle 7.5 signalé à tort non conforme	Sur un Windows en français, `auditpol` renvoie « Réussite » au lieu de « Succès », avec des accents mal encodés	Normalisation de la valeur, indépendante de la langue : faux positif corrigé
Redémarrage à distance refusé	`Restart-Computer -ComputerName` utilise RPC, bloqué par le pare-feu durci	Redémarrage lancé via WinRM : `Invoke-Command { Restart-Computer }`
Accès refusé après durcissement	Mot de passe mal saisi, avec désormais un verrouillage après 5 échecs	Test des identifiants sur un seul poste avant l'audit ; illustre l'efficacité de la politique de verrouillage

7. Conclusion

L'outil développé permet de mesurer, corriger et prouver l'amélioration du durcissement d'un parc Windows de façon automatisée et reproductible. Sur les postes traités, le score de conformité double (de 47,1 % à 94,1 %) et les non-conformités passent de 18 à 2, les écarts restants étant des limites connues et documentées du laboratoire.

Ce projet met en œuvre une démarche d'audit complète : état des lieux, priorisation par sévérité, validation des changements par simulation, remédiation, puis mesure du gain. Le code source et les rapports sont disponibles sur GitHub : **github.com/leslie924**.